

Clase 338 — Generación de informes y flujos de trabajo con IA

Parte: **18 — IA aplicada a la ciberseguridad** · Fuente: kali-mcp (MIT) · PTES Reporting · OWASP WSTG

 Duración estimada: **90 min** · Nivel: **Intermedio**

Objetivo

Usar la IA para lo que mejor hace en un engagement: **compilar hallazgos y redactar informes** consistentes y legibles — sin que "invente" hallazgos. Verás cómo el flujo `/kali-finish` de kali-mcp consolida una sesión y cómo el profesional verifica cada afirmación antes de firmar.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

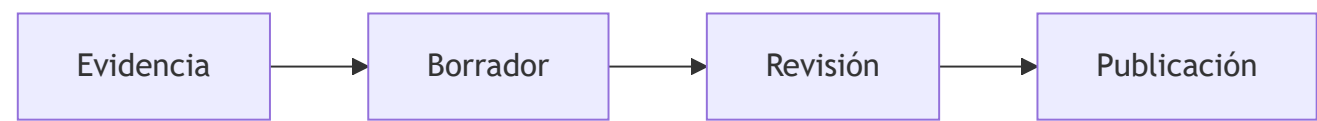
- 1. **Generar** un borrador de informe a partir de los datos de una sesión.
- 2. **Verificar** que cada hallazgo del informe está respaldado por evidencia real.
- 3. **Adaptar** el tono a la audiencia (resumen ejecutivo vs técnico).
- 4. **Estandarizar** informes con plantillas y flujos reproducibles.
- 5. **Evitar** el mayor riesgo: hallazgos alucinados en un documento oficial.

Temas

#	Tema	Por qué importa
1	La IA como redactora, no como fuente	Redacta bien; los hechos los pones tú.
2	<code>/kali-finish</code> y consolidación	Compila la sesión en un reporte inicial.
3	Verificación de hallazgos	Cada hallazgo debe tener evidencia reproducible.
4	Audiencias del informe	Ejecutivo vs técnico (ver clase 085).
5	Plantillas y consistencia	Informes homogéneos y auditables.

Explicación en profundidad

Generar informes exige separar hechos, inferencias y redacción. La IA transforma evidencia sanitizada bajo una plantilla; el revisor valida cada hallazgo, severidad, alcance y recomendación antes de publicar.



El diagrama separa lenguaje de autoridad. El modelo puede proponer; la política determina si la operación pertenece al alcance; la herramienta produce evidencia; y una persona o control determinista decide transiciones de alto impacto. Se registran prompt relevante, parámetros validados, versión, salida, aprobador y cleanup sin almacenar secretos innecesarios.

Caso razonado

El borrador afirma exfiltración donde solo hubo acceso. La revisión reduce el lenguaje al efecto demostrado.

 Glosario operativo

Término	Definición
Provenance de informe	Relación entre afirmación, fuente, transformación y aprobador.
Guardrail	Capa que reduce una capacidad o detecta su uso; no garantía absoluta.
Audit trail	Registro ordenado de solicitudes, decisiones, ejecuciones y resultados.

 Criterio de dominio

El alumno demuestra dominio cuando reproduce el flujo completo, puede atribuir cada acción, evita que texto no confiable otorgue autoridad y explica qué control contiene un fallo del modelo.

 Definiciones y características

Borrador asistido : Primer informe generado por IA a partir de los datos de la sesión; es un punto de partida, no el entregable final.

Hallazgo alucinado : Vulnerabilidad que la IA describe pero que no existe o no se demostró. Incluirlo en un informe es un fallo grave de credibilidad y responsabilidad.

Trazabilidad hallazgo→evidencia : Cada afirmación del informe debe enlazar con la evidencia (comando, captura, log) que la respalda.

Plantilla de informe : Estructura fija (resumen ejecutivo, metodología, hallazgos, anexos) que la IA rellena de forma consistente.

 Herramientas y preparación

Los datos de una sesión de laboratorio (de las clases 333–336) y un LLM. Ten a mano la evidencia cruda para **verificar** lo que el informe afirme.

 Laboratorio guiado

1. **Borrador.** Genera con IA un informe a partir de los hallazgos de tu sesión de laboratorio.
2. **Verificación.** Para cada hallazgo, localiza la evidencia que lo respalda. Marca los que **no** puedes respaldar.
3. **Depuración.** Elimina o corrige los hallazgos sin evidencia (alucinaciones).

4. **Dos audiencias.** Pide a la IA un resumen ejecutivo (sin jerga) y una sección técnica del mismo hallazgo.
5. **Plantilla.** Define una plantilla reutilizable y comprueba que el informe la respeta.

Ejercicios

1. ¿Por qué la IA es buena redactando pero peligrosa como fuente de hechos?
2. Diseña la tabla "hallazgo → evidencia" para verificar un informe.
3. Reescribe un hallazgo técnico como resumen ejecutivo.
4. ¿Qué revisarías siempre antes de entregar un informe generado con IA?
5. Crea una plantilla mínima de informe de pentest.

Reto verificable

Genera un mini-informe con IA de tu sesión y entrégalo **solo** con hallazgos verificados, documentando qué eliminaste por falta de evidencia.

Criterio de aceptación: cada hallazgo del informe final tiene evidencia reproducible; listas explícitamente lo que descartaste; el resumen ejecutivo no tiene jerga.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Entregar el borrador de la IA sin revisar	Puede contener hallazgos alucinados. Verifica todo.
Informe técnico para la dirección	Audiencia equivocada. Separa ejecutivo y técnico.
Hallazgos sin evidencia	No los incluyas; sin evidencia no hay hallazgo.
Cifras/severidades inventadas	Calcula el CVSS tú y verifícalo (clase 085).

Preguntas frecuentes

 **¿Puedo dejar que la IA escriba todo el informe?** El borrador sí; el entregable final, no, sin tu verificación. Firmas tú, y la responsabilidad por lo que afirma el documento es tuya.

 **¿Cómo evito que invente hallazgos?** Trabaja con trazabilidad: obliga a que cada afirmación cite su evidencia y elimina lo que no puedas respaldar con la salida real de una herramienta.

Referencias

- [PTES — Reporting · FIRST CVSS](#)
- kali-mcp (MIT) — <https://github.com/pabperez/kali-mcp>
- Clase [085](#) (reporte profesional).

Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.

Clase anterior

Clase 337 — IA para el lado defensivo: SOC, triaje y forense

Siguiente clase

Clase 339 — Riesgos, guardrails, OPSEC y ética del hacking con IA